PURPOSE CAPITAL
Guiding Capital with Purpose

POLICY · INFORMATION SYSTEMS

# Information Systems Security Policy

Version **0.9** DRAFT

| | |
|---|---|
| Owner | Chief Executive Officer |
| Next review | 12 months after adoption |
| Confidentiality | Internal |

DRAFT

**Purpose Capital S.A.**
Rue Joseph Essono Balla, Elig-Essono, Yaoundé (Cameroun)

Courtesy translation — the French version prevails.
Issued on 12 November 2026

# Document control sheet

Courtesy translation — the French version prevails.

| | | | |
|---|---|---|---|
| **Version** | 0.9 — Draft | | |
| **Title** | Information Systems Security Policy | | |
| **Type · domain** | Policy · Information systems | **Confidentiality** | Internal |
| **Owner** | Chief Executive Officer | | |
| **Distribution** | No mandatory reading designated | | |
| **Effective date** | On adoption | **Next review** | 12 months after adoption |

## APPROVAL WORKFLOW

| Step | Function | Electronic sign-off | Handwritten signature |
|---|---|---|---|
| Drafting | Compliance Officer | Pending | Date and signature |
| Approval | Chief Executive Officer | Pending | Date and signature |
| Adoption by the Board of Directors | Chairman of the Board of Directors | Pending | Date and signature |

## REVISION HISTORY

| Version | Date | Purpose | By |
|---|---|---|---|
| 0.9 | 20 October 2026 | Formatting: adoption dates and signatures moved to the document control sheet | Compliance Officer |
| 0.9 | 20 October 2026 | Initial draft submitted to the Board of Directors | Compliance Officer |

## REFERENCE TEXTS

| | |
|---|---|
| Law No. 2024/017 of 23 December 2024 on the protection of personal data in Cameroon<br>Overview · droitmediasfinance.com | Security of personal data, obligations towards processors, notification of breaches |
| Law No. 2010/012 of 21 December 2010 on cybersecurity and cybercrime in Cameroon<br>Overview · dig.watch | Cameroonian cybersecurity framework, offences against information systems, role of ANTIC |
| COSUMAF General Regulation of 23 May 2023<br>Official text · cosumaf.org | Retention of documents and records, and COSUMAF access to them |
| ISO/IEC 27001 and 27002 (2022) — Information security | International standard: information security management system and security controls (ISO 27002) |
| NIST — Cybersecurity Framework 2.0 (2024)<br>Official text · nvlpubs.nist.gov | International good practice: six functions (govern, identify, protect, detect, respond, recover) |
| ANSSI — IT Hygiene Guide<br>Official text · cyber.gouv.fr | Comparable jurisdiction: IT hygiene measures for small organisations |
| Basel Committee — Revisions to the Principles for the Sound Management of Operational Risk (2021)<br>Official text · bis.org | International good practice: information security and operational resilience |

DRAFT

# Contents

**I. General provisions**

Article 1 — Purpose
Article 2 — Why this policy matters
Article 3 — Scope
Article 4 — Definitions

**II. Organisation**

Article 5 — Roles
Article 6 — Principles

**III. Information**

Article 7 — Classification
Article 8 — Where information is kept

**IV. Access and identities**

Article 9 — Named accounts and authentication
Article 10 — Privileged accounts and emergency account
Article 11 — Joiners, movers and leavers
Article 12 — Access review

**V. Workstations, email and online services**

Article 13 — Workstations and telephones
Article 14 — Email
Article 15 — Online services and service providers
Article 16 — Remote working

**VI. Data, logs and changes**

Article 17 — Backups
Article 18 — Development and changes to the Guichet
Article 19 — Logging

**VII. Incidents**

Article 20 — Reporting and handling
Article 21 — Lessons learned

**VIII. Awareness, control and final provisions**

Article 22 — Awareness
Article 23 — Control
Article 24 — Breaches
Article 25 — Review and entry into force

**Appendices**

Appendix “Acceptable use charter” — Acceptable use charter for digital tools
Appendix “Access matrix” — Access matrix and six-monthly review
Appendix “Joiners and leavers” — Staff Member joiner and leaver checklist
Appendix “Security incident report form” — Security incident report form
Appendix “Minimum measures” — Minimum measures by tool

DRAFT

# Title I — General provisions

### Article 1 — Purpose

This policy sets the rules that protect the information of Purpose Capital S.A. (the "Company") and of its clients against loss, theft, disclosure and unavailability. It states who is responsible, what everyone must do, and what the Company expects of its service providers.

It replaces the minimum requirements of Article 19 of the Risk Management Policy and applies together with the Business Continuity Plan and the Outsourcing Policy.

### Article 2 — Why this policy matters

A brokerage firm holds its clients' most sensitive information: their identity, their accounts, their assets, their orders. A hacked mailbox is enough to divert a bank transfer; a lost computer, to expose hundreds of files. Cameroonian law on the protection of personal data requires the Company to protect such data and to report any breach.

The Company is small, almost all its tools are online and its IT is entrusted to a service provider. Security therefore rests mainly on a few simple rules applied by everyone, and on control of access accounts.

### Article 3 — Scope

The policy applies:

- to all Staff Members, senior managers, directors, interns and service providers who use the Company's tools;
- to all tools: workstations, business telephones, online email and office applications, the Guichet, the website, online banking, access to the systems of BVMAC and of the Central Securities Depository;
- wherever work is carried out: office, home or travel.

### Article 4 — Definitions

- **Information system**: all the hardware, software, online services and data used by the Company.
- **Privileged account**: an account that makes it possible to administer a service, create users or modify security settings.
- **Multi-factor authentication**: a login that requires, in addition to the password, a second element (a code from an app, a passkey).
- **Security incident**: an event that compromises or may compromise the confidentiality, integrity or availability of information or of a tool.

DRAFT

# Title II — Organisation

## Article 5 — Roles

| Function | Responsibilities |
|---|---|
| Board of Directors | Approves the policy; receives each year the review of security and incidents |
| Chief Executive Officer | Responsible for the security of the information system; allocates resources; holds, together with the Chairman of the Board, access to the emergency account |
| Internal IT officer | Staff Member designated by the Chief Executive Officer: maintains the access matrix, monitors the service provider, organises joiners and leavers, first point of contact in the event of an incident |
| IT service provider | Administers the tools in accordance with its contract and this policy; applies updates; reports incidents within 24 hours |
| RCCI | Monitors application of the policy; keeps the incident register; checks the protection of personal data |
| Staff Members | Apply the acceptable use charter in Appendix “Acceptable use charter”; report any incident or doubt without delay |

## Article 6 — Principles

1. **Need to know**: everyone accesses only the information necessary for his or her work.
2. **Least privilege**: administrative rights are reserved for those who need them, and are used from separate accounts.
3. **The Company stays in control**: it holds its main accounts and its emergency account itself, and never depends on a single service provider or a single person to access its data.
4. **Simplicity**: a rule that is understood and applied is better than a perfect rule that is ignored.

DRAFT

# Title III — Information

### Article 7 — Classification

| Level | Examples | Rules |
|---|---|---|
| Public | Website, brochure, press releases | Free distribution after approval |
| Internal | Procedures, internal memos, schedules | Staff Members and service providers bound by a confidentiality agreement |
| Confidential | Client files, orders, positions, personal data, accounts, control reports | Access according to the matrix in Appendix “Access matrix”; never via personal email; encryption for any external transmission |
| Secret | Inside information, suspicious transaction reports, passwords and keys | Named and traced access; never copied outside the designated tools |

An unmarked document is treated as **internal**. A document containing client data is always **confidential**.

### Article 8 — Where information is kept

The Company's information is stored in its tools: the Company's online storage space, business email and the Guichet. It is not kept on a lasting basis on a workstation's hard drive, on a personal USB stick or in a personal online service. Confidential paper documents are kept under lock and key.

DRAFT

# Title IV — Access and identities

### Article 9 — Named accounts and authentication

- Each person has a **named account**; shared accounts are prohibited, except for a shared inbox without administrative rights.
- **Multi-factor authentication is mandatory** for all accounts: email and office applications, the Guichet (desk and managers), hosting providers, online banking, domain name registrar, access to market systems.
- Passwords are at least 12 characters long, unique to each service and kept in the Company's password vault. They are never disclosed, not even to the service provider or to a senior manager.

### Article 10 — Privileged accounts and emergency account

- Administrative rights are assigned to accounts separate from day-to-day working accounts, for no more than two persons per service in addition to the service provider.
- The Company holds an **emergency** administrator **account** for its email, without a licence, attached to the provider's technical domain, protected by a physical security key, and whose use triggers an alert. Its access credentials are kept under seal, under the joint responsibility of the Chief Executive Officer and the Chairman of the Board of Directors.
- Any use of an emergency account is recorded and justified to the RCCI.

### Article 11 — Joiners, movers and leavers

Whenever someone joins, changes role or leaves, the IT officer applies the checklist in Appendix “Joiners and leavers”. When a Staff Member leaves, his or her access is **cut off the same day**, his or her equipment is returned, and the passwords and keys he or she knew are changed. A service provider's access is cut off at the end of its assignment.

### Article 12 — Access review

Every six months, the IT officer and the RCCI review the access matrix in Appendix “Access matrix”: each account must correspond to a person currently present and to a need. Unnecessary accounts are deleted. The review is dated and signed.

DRAFT

# Title V — Workstations, email and online services

### Article 13 — Workstations and telephones

- Only **laptops supplied by the Company** process confidential data. They are encrypted, protected by a password or PIN and locked automatically after five minutes of inactivity.
- The operating system and software are **updated** automatically; a security update is installed within seven days.
- The antivirus built into the operating system is active and up to date. Software installation is reserved for the service provider or the IT officer.
- The business telephone is protected by a PIN and can be wiped remotely.
- A lost or stolen device is reported immediately: it is blocked and wiped remotely.

### Article 14 — Email

Email is the most common entry point for fraud. The Company:

- publishes the authentication records for its domain (SPF, DKIM, DMARC) to prevent messages from being sent in its name;
- filters incoming messages and flags messages from outside the Company;
- prohibits automatic forwarding of business email to a personal address.

Staff Members **do not act on any request received by email for a payment, a change of bank details or a password** without having confirmed it through another channel, using the number already on file (Client Onboarding Procedure, Article 17).

### Article 15 — Online services and service providers

Each online service used by the Company (email and office applications, hosting of the website and the Guichet, database, message sending, document repository) is entered in the outsourcing register and follows the Outsourcing Policy, in particular:

- the Company is the holder of its accounts and its data, and holds the main access rights to them;
- the location of the data is known, and any transfer of personal data outside Cameroon complies with the law;
- the available security settings are enabled: multi-factor authentication, login alerts, logging.

Technical keys (API keys, application secrets) are kept in the hosting provider's protected variables, never in code, in a message or in a document. Each API provider is subject to a spending cap and a budget alert. A key is renewed without delay when a person who had access to it leaves or if it may have been exposed, and at least once a year.

### Article 16 — Remote working

Remote working follows the rules of the Business Continuity Plan (Article 17). In particular: no public Wi-Fi network, with a preference for the telephone's shared connection; screen out of sight of third parties; no confidential document printed outside the office unless necessary.

DRAFT

# Title VI — Data, logs and changes

### Article 17 — Backups

Important data exists in **three copies, on two different media, one of which is offline or with a provider other than the main one**. Backups are made daily. Restoration is tested each quarter, in accordance with the Business Continuity Plan.

### Article 18 — Development and changes to the Guichet

The Guichet, developed and operated by the Company, follows the rules below:

- every change goes through a separate branch, a preview checked by a manager, and then a reviewed merge before deployment to production;
- database changes are applied and checked before deployment of the code that uses them;
- real client data is not used outside the production environment;
- rolling back to the previous version is possible at any time, and the procedure for doing so is written down;
- access to the desk requires the second factor; no user may approve his or her own proposal or change his or her own access level.

### Article 19 — Logging

Logins, administrative actions and sensitive operations are logged: email login logs, the chained audit log of the Guichet, hosting providers' histories. Logs are kept for at least one year, and for ten years where they evidence a client's order or transaction. The IT officer reviews login alerts each week. A break in the Guichet audit chain is a security incident.

DRAFT

# Title VII — Incidents

### Article 20 — Reporting and handling

Any Staff Member who observes or suspects an incident (a suspicious link clicked, a lost device, an account used by a third party, a fraudulent payment request, a document leak) **reports it immediately** to the IT officer and the RCCI, without trying to resolve it alone or erasing any traces. The incident is reported within 24 hours on the form in Appendix “Security incident report form”.

Handling follows Article 12 of the Business Continuity Plan: isolate, block, prevent fraud, restore, inform. An incident affecting client data is brought to the attention of the Chief Executive Officer, who decides whether to inform the clients concerned, the data protection authority under the conditions laid down by law and, if the incident is significant, COSUMAF.

### Article 21 — Lessons learned

Every significant incident is subject to a root cause analysis and an action plan, followed up by the RCCI in accordance with the Internal Control and Compliance Charter.

DRAFT

# Title VIII — Awareness, control and final provisions

### Article 22 — Awareness

Each Staff Member signs the acceptable use charter in Appendix “Acceptable use charter” on joining. Awareness training on fraud and phishing is provided each year and whenever a new form of fraud is observed; it may include a simulated phishing exercise.

### Article 23 — Control

The RCCI checks application of the policy in accordance with the annual control plan, in particular the six-monthly access review, restoration tests, the minimum measures in Appendix “Minimum measures” and the follow-up of incidents. The annual independent review also covers information systems security.

### Article 24 — Breaches

Failure to comply with this policy may lead to disciplinary sanctions, in accordance with the Code of Conduct and the internal rules, without prejudice to any prosecution provided for by law in the event of an offence against an information system.

### Article 25 — Review and entry into force

The policy is reviewed at least once a year and after any significant incident or major change of tool. Any amendment is approved by the Board of Directors.

This policy enters into force on the date of its adoption by the Board of Directors, as indicated in the document control sheet.

DRAFT

APPENDIX “ACCEPTABLE USE CHARTER” · INFORMATION SYSTEMS SECURITY POLICY · UNDERTAKING

# Acceptable use charter for digital tools

Version 0.9
Internal

**Completed by** Each Staff Member, intern or service provider with an account

**Frequency** On joining and upon each revision of the charter **Kept by** Staff Member's personnel file; copy to the RCCI

In using the tools of Purpose Capital S.A., I undertake to comply with the following rules.

**My access**

1. I use only my named account, with multi-factor authentication. I never lend my access and I never disclose a password or code to anyone, not even to a senior manager or to the IT service provider.
2. I use a different password for each service, kept in the Company's password vault.

**My equipment** 3. I process client data only on equipment supplied by the Company. I lock my workstation whenever I leave it. 4. I do not install any software and I do not plug in any unknown USB stick. 5. I immediately report the loss or theft of my computer or telephone.

**Information** 6. I save my documents in the Company's storage spaces, never in a personal service or by forwarding them to my personal email. 7. I send client data only to people who need it, through the Company's channels. I neither receive nor transmit orders through a personal messaging service. 8. I do not discuss confidential information in a public place and I keep my screen out of sight of third parties.

**Fraud** 9. I do not act on any request received by email for a payment, a change of bank details or a password without having confirmed it through another channel, using the number already on file. 10. If I am in doubt about a message, I do not click and I report it to the IT officer.

**Incidents** 11. I immediately report any incident or doubt to the IT officer and the RCCI, without trying to resolve it alone.

**Monitoring** 12. I am aware that use of the Company's tools is logged, in compliance with the law, and that any breach may lead to disciplinary sanctions.

NAME AND POSITION _____

DATE _____

SIGNATURE, PRECEDED BY "READ AND APPROVED" _____

DRAFT

APPENDIX "ACCESS MATRIX" · INFORMATION SYSTEMS SECURITY POLICY · REGISTER

# Access matrix and six-monthly review

Version 0.9
Internal

**Completed by** IT officer; review with the RCCI **Frequency** Updated upon each joiner, mover or leaver; reviewed every six months **Kept by** RCCI · ten years

One row per account. Level: U user, A administrator, U+ user with approval rights. MFA: multi-factor authentication enabled. Example rows to be completed.

| Service | Account holder (position) | Level | MFA | Opened on | Justification of need | Review 1 (date, retained?) | Review 2 (date, retained?) | Closed on |
|---|---|---|---|---|---|---|---|---|
| Email and office applications | Chief Executive Officer | A | ☐ | | Tenant administration | | | |
| Email and office applications | Emergency account | A | ☐ physical key | | Emergency access, under seal | | | |
| Email and office applications | IT service provider | A | ☐ | | Managed IT services contract | | | |
| Guichet (desk) | Manager | U+ | ☐ | | Approvals, team management | | | |
| Guichet (desk) | Desk operator | U | ☐ | | Processing of files and orders | | | |
| Guichet hosting provider and database | | A | ☐ | | Operation of the Guichet | | | |
| Code repository | | A | ☐ | | Development of the Guichet | | | |
| Website hosting provider and DNS, domain registrar | | A | ☐ | | Website and domain | | | |
| Online banking | | U | ☐ | | Payments, dual signature | | | |
| BVMAC and Central Securities Depository systems | | U | ☐ | | Trading and settlement | | | |
| Password vault | | A | ☐ | | Secrets management | | | |

REVIEW OF · ACCOUNTS DELETED

IT OFFICER

RCCI

DRAFT

APPENDIX "JOINERS AND LEAVERS" · INFORMATION SYSTEMS SECURITY POLICY · CHECKLIST

# Staff Member joiner and leaver checklist

Version 0.9
Internal

**Completed by** IT officer **Frequency** Upon each joiner, change of role or leaver, including interns and service providers

**Kept by** Staff Member's personnel file; copy to the RCCI

NAME AND POSITION ☐ JOINER ☐ CHANGE ☐ LEAVER EFFECTIVE DATE

| ✓ | Joiner or change | ✓ | Leaver (same day) |
|---|---|---|---|
| ☐ | Acceptable use charter (Appendix "Acceptable use charter") signed | ☐ | Accounts blocked: email, Guichet, hosting providers, bank, market systems |
| ☐ | Named account created, multi-factor authentication enabled | ☐ | Open sessions closed on all devices |
| ☐ | Rights assigned according to role, entered in the matrix (Appendix "Access matrix") | ☐ | Computer, telephone, security keys and badges returned |
| ☐ | Encrypted laptop and telephone handed over, inventory signed | ☐ | Mailbox transferred to the manager, automatic reply set up |
| ☐ | Access to the password vault, limited to the necessary secrets | ☐ | Known shared passwords and technical keys changed |
| ☐ | Awareness training on fraud and on this policy | ☐ | Bank and market authorisations withdrawn with third parties |
| ☐ | Bank or market authorisations requested if necessary | ☐ | Access matrix updated; licence released |
| ☐ | Change: previous rights withdrawn | ☐ | Written reminder of the duty of confidentiality |

IT OFFICER · DATE STAFF MEMBER · SIGNATURE RCCI SIGN-OFF

DRAFT

APPENDIX "SECURITY INCIDENT REPORT FORM" · INFORMATION SYSTEMS SECURITY POLICY · FORM

# Security incident report form

Version 0.9
Internal

**Completed by** Any Staff Member, then the IT officer and the RCCI **Frequency** Within 24 hours of discovery

**Kept by** RCCI (incident register) · ten years

Supplements the incident form of the Risk Management Policy (Appendix "Security incident report form") for security incidents. In an emergency, call first, write afterwards.

REPORTED BY _____ DATE AND TIME OF DISCOVERY _____ TOOL OR DEVICE CONCERNED _____

Type: ☐ Fraudulent message or link clicked ☐ Account used by a third party ☐ Computer or telephone lost or stolen ☐ Malware ☐ Fraudulent payment request ☐ Information sent to the wrong recipient ☐ Service unavailable ☐ Other

| | |
|---|---|
| **What happened** | |
| **Information or clients concerned** | |
| **What I have already done** | |

HANDLING

☐ Device isolated ☐ Passwords changed and sessions closed ☐ Banks alerted ☐ Data restored ☐ Service provider informed

Personal data affected: ☐ No ☐ Yes → decision of the Chief Executive Officer: ☐ clients informed ☐ data protection authority informed ☐ COSUMAF informed

CAUSE AND MEASURES TO PREVENT RECURRENCE _____ CLOSED ON · IT OFFICER · RCCI _____

DRAFT

APPENDIX "MINIMUM MEASURES" · INFORMATION SYSTEMS SECURITY POLICY · REFERENCE TABLE

# Minimum measures by tool

Version 0.9
Internal

**Completed by** IT officer, with the service provider **Frequency** Annual review and upon each new tool **Kept by** RCCI · checked during the annual control

The "In place" column is ticked at each check; a missing measure becomes an action in the control plan.

| Tool | Minimum measures | Who | Check | In place |
|---|---|---|---|---|
| Laptops | Disk encryption; automatic updates; active antivirus; locking after 5 minutes; no administrative rights for the user; remote wipe possible | Service provider | Six-monthly | ☐ |
| Business telephones | Lock code; updates; remote wipe; business apps only for client data | IT officer | Six-monthly | ☐ |
| Online email and office applications | Multi-factor authentication for all; security defaults enabled; emergency account under seal; external automatic forwarding blocked; login alerts; SPF, DKIM and DMARC published | Service provider, Chief Executive Officer | Quarterly | ☐ |
| Guichet | Second factor mandatory on the desk; segregation of proposal and approval; chained audit log checked; review before merging into the production branch; secrets in protected variables; API spending caps | Guichet manager | Quarterly | ☐ |
| Guichet database | Named console access with second factor; automatic backups and external copy; service key never exposed client-side | Guichet manager | Quarterly | ☐ |
| Website and domain name | Second factor with the hosting provider and the registrar; domain transfer lock; automatic renewal; HTTPS certificate | Chief Executive Officer | Annual | ☐ |
| Online banking | Dual signature of payments; individual tokens; caps; alerts | Chief Executive Officer | Six-monthly | ☐ |
| Password vault | Second factor; sharing by folder on a need basis; emergency access defined | IT officer | Six-monthly | ☐ |
| Backups | Three copies, two media, one offline or with another provider; restoration tested | Service provider | Quarterly | ☐ |
| Office network | Strong Wi-Fi password; separate guest network; up-to-date equipment; dual internet access | Service provider | Annual | ☐ |

CHECKED ON _____ IT OFFICER _____ RCCI _____

DRAFT